

Meridian Bank

Breach Notification Playbook (GLBA + State Banking + Contract)

DOCUMENT ID

IJZ-MER-BRPL-20260627

VERSION

v3.0

PERIOD

Operational Playbook

PREPARER

Ijezie Risk Advisory

CLASSIFICATION

CONFIDENTIAL

STATUS

Draft - Pending Review

title: "Breach Notification Playbook" doc_id: IJZ-MER-BRPL-20260627 date: 2026-06-27 classification: CONFIDENTIAL
preparer: Ijezie Risk Advisory persona: Meridian Bank, National Association engagement: vCISO Examiner Readiness,
2026 Q2 period: 2026 Q2 frameworks:

- GLBA Interagency Guidance on Response Programs (2005)
- GLBA Safeguards Rule (16 CFR Part 314)
- State breach notification (NC, SC, VA, TN)
- NYDFS 23 NYCRR 500 (adjacent, 72-hour notification)
- FFIEC IT Examination Handbook (Information Security Booklet)
- SOX ITGC (material incident disclosure)
- Contractual notification obligations under MSAs

Breach Notification Playbook

1. Why This Playbook Exists

Meridian Bank maintains customer information for 2.4 million retail and commercial customers across North Carolina, South Carolina, Virginia, and Tennessee. A data security incident affecting customer non-public information (NPI) carries obligations under federal banking guidance, multi-state breach notification laws, contractual commitments with vendors and correspondent banks, and the bank's SOX disclosure controls. This playbook consolidates those obligations into a single decision framework.

This playbook is grounded in the Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice (2005) issued by the federal banking agencies. The Guidance establishes a four-element response program: (1) assessment of the nature and scope of the incident, (2) notification to the primary federal regulator, (3) notification to customers when warranted, and (4) reasonable investigation and response.

2. Triggering Events

The playbook activates upon any of the following:

- Confirmed unauthorized access to or acquisition of customer NPI stored by Meridian or a vendor processing on Meridian's behalf
- Suspected unauthorized access that cannot be ruled out within 24 hours
- Loss of devices or media containing unencrypted customer NPI
- Vendor-reported breach affecting Meridian customer data
- Law enforcement request for delayed notification (handled case-by-case with General Counsel)
- Regulatory inquiry suggesting a notifiable event

3. The Response Program (GLBA Four-Element Framework)

3.1 Element 1: Assessment

The CISO leads the initial assessment with support from IT, BSA, Fraud Operations, and the vendor management function. The assessment must determine: the nature of the incident, the number of customers potentially affected, the type of NPI involved, whether the incident resulted in unauthorized acquisition (versus mere access), and whether the information was encrypted or rendered unusable.

Target completion: within 48 hours of trigger. For vendor-reported incidents, the vendor's assessment timeline is supplemented by Meridian's independent analysis. Vendor MSAs require notification within 24 hours of the vendor's own discovery (Section 8).

3.2 Element 2: Notification to the Primary Federal Regulator

The OCC is the primary federal regulator for Meridian Bank, N.A. The General Counsel coordinates written notification to the OCC supervisory office within 24 to 48 hours of confirmed notifiable incident. Notification includes: incident summary, customer NPI affected, number of customers, mitigation steps taken, and any pending customer notification.

For incidents affecting wealth management customers, Pershing and the SEC are notified as applicable. For card services incidents affecting the Fiserv perimeter, the card networks are notified per their operating rules.

3.3 Element 3: Customer Notification

Customer notification is required when the investigation determines that misuse of customer NPI has occurred or is reasonably possible. The standard is from the 2005 Interagency Guidance: notify customers as soon as possible when the bank determines that misuse of customer information has occurred or is reasonably possible.

The standard notification timeline is 30 days from incident confirmation, with allowances for law enforcement delay requests. Notification methods: written notice to the customer's address of record, email for customers with electronic consent, telephone for high-risk incidents, and substitute notice (website posting, statewide media) where required by state law.

3.4 Element 4: Reasonable Investigation and Response

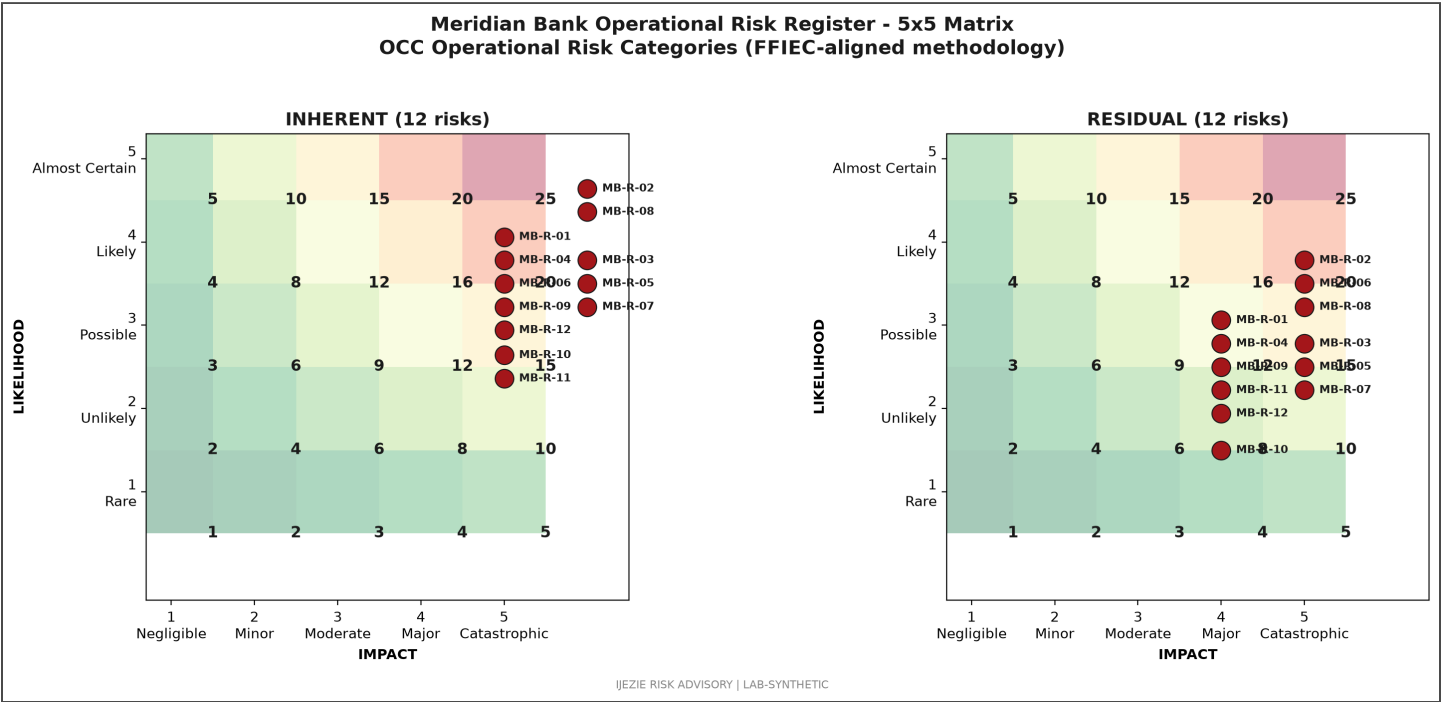
Investigation continues after initial notification as needed. Response activities include: credit monitoring offering (typically 12 to 24 months), fraud alert assistance, dedicated incident response call center, and identity theft protection where required by state law or contractual obligation.

4. Customer Notification Decision Tree

The decision tree below guides the customer notification decision:

- Step 1: Did unauthorized acquisition occur? If no, document and consider precautionary notification.
- Step 2: Was the information encrypted or rendered unusable? If yes, notification may not be required for GLBA purposes.
- Step 3: What type of NPI was involved? (SSN, account number, password, biometric, etc.) Higher sensitivity triggers notification regardless of encryption analysis.
- Step 4: How many customers are affected? Aggregate count informs notification method and substitute notice triggers.

- Step 2: Was the information encrypted or rendered unusable? If yes, notification may not be required for GLBA purposes.



5. State Notification Matrix (NC, SC, VA, TN)

STATE	TRIGGER	TIMELINE	FORM	PENALTY
North Carolina (N.C.G.S. 75-65)	Unauthorized acquisition of personal information	As expeditiously as possible, without unreasonable delay	Written to last known address; substitute notice if more than 1,000 affected	Civil action by Attorney General
South Carolina (S.C. Code 39-1-90)	Unauthorized acquisition of personal information	Without unreasonable delay, consistent with law enforcement needs	Written; email if consented	Civil penalty
Virginia (Va. Code 18.2-186.6)	Unauthorized access and acquisition of unencrypted personal information	Without unreasonable delay	Written; substitute notice if more than 1,000 affected	Civil penalty up to \$150,000 per breach
Tennessee (Tenn. Code 47-18-2107)	Unauthorized acquisition of personal information	As quickly as possible, without unreasonable delay	Written	Civil action by Attorney General

For multi-state incidents, Meridian applies the strictest applicable timeline and most protective notification content. The General Counsel coordinates state Attorney General notifications as required.

6. Federal Regulator Coordination

6.1 OCC Notification

The OCC supervisory office receives written notification within 24 to 48 hours of confirmed incident. Notification content: incident summary, customer impact, mitigation steps, and law enforcement coordination status. The CRO and General Counsel sign jointly.

6.2 NYDFS 23 NYCRR 500 (Adjacent)

Although Meridian has no NY operations, NYDFS 23 NYCRR 500 Section 500.17(a) requires notification to the Superintendent of Financial Services within 72 hours of determining a cybersecurity event has occurred. This is tracked as an adjacent framework because correspondent banking relationships with NY-chartered institutions can pull Meridian into scope for material events. The General Counsel and CISO evaluate NYDFS applicability per incident.

6.3 Federal Reserve (for FedLine incidents)

Incidents affecting FedLine Advantage access or wire transfer operations trigger Federal Reserve notification under Operating Circular 5. Notification is coordinated through Treasury Operations and the General Counsel.

6.4 Other Federal Agencies

For incidents affecting wealth management customers, the SEC is notified as applicable. For incidents with potential national security implications, CISA and the FBI are notified through established channels.

7. Worked Example: MB-INC-2025-001 BEC Incident

Incident summary: In October 2025, a regional construction firm (commercial loan customer) received a spoofed CFO email instructing redirection of a \$2.3M outbound wire to a new beneficiary account. The customer's accounts payable clerk released the wire through Meridian's commercial online banking portal. Meridian's wire authentication controls flagged the transaction for callback verification because the beneficiary bank had changed within 14 days.

Timeline (actual):

- T+0: Wire released by customer
- T+38min: Meridian callback verification reached the legitimate CFO by direct phone line (not email). CFO confirmed the request was fraudulent.
- T+45min: BSA Officer escalated to incident response
- T+1h 7min: Treasury Operations initiated wire recall through correspondent bank
- T+2h 12min: Federal Reserve recall request submitted for outbound wire
- T+24h: \$1.8M recovered through correspondent bank reversal; remaining \$500K under further recovery action

Regulatory treatment: Incident classified as attempted unauthorized wire transfer, not customer NPI breach. No GLBA customer notification triggered because no customer NPI was acquired by the threat actor. OCC supervisory notification occurred within 24 hours as a matter-of-course under the BSA Officer's standing escalation protocol.

Lessons learned incorporated into this playbook:

- Wire callback threshold lowered from \$500K to \$250K for first-time beneficiary changes
 - Dual approval required for any wire where beneficiary bank changed within 14 days
-

-
- Quarterly BEC tabletop cadence with top 50 commercial customers
 - Wire authentication hardening project tracked as OPEN-2026-Q2-04

8. Vendor Notification (MSAs)

Critical vendor MSAs require vendor notification to Meridian within 24 hours of vendor discovery of a security incident affecting Meridian customer NPI. The Head of Third-Party Risk Management maintains the notification register and coordinates vendor incident response. Reciprocal obligations: Meridian notifies affected vendors of incidents affecting vendor systems within the same 24-hour window.

9. Documentation and Records Retention

All breach response documentation is retained for 7 years per the Records Retention Policy. Documentation includes: incident timeline, decision rationale for notification (or non-notification), regulator correspondence, customer notification records, vendor communications, root cause analysis, and remediation tracking.

10. Tabletop Schedule

- Q1 2026: Vendor breach at FIS or Fiserv (completed)
- Q2 2026: BEC tabletop with top 50 commercial customers (scheduled)
- Q3 2026: Ransomware on FIS-hosted core (scheduled)
- Q4 2026: Wire fraud with cross-border correspondent banking (scheduled)

11. What This Demonstrates

This playbook demonstrates that Meridian operates a multi-jurisdictional breach notification program aligned to GLBA Interagency Guidance, with state-specific timelines for NC, SC, VA, and TN, adjacent NYDFS tracking, and tested vendor coordination. The BEC worked example illustrates practical application under realistic conditions.

12. Review Schedule

This playbook is reviewed semi-annually by the General Counsel and CISO, and annually by the Board Risk Committee. Next scheduled review: 2026-12-31.

Prepared by Ijezie Risk Advisory for Meridian Bank examiner readiness engagement.